BinsApp OTP Security Summary

Backend

1. Twilio Error Handling

Files: src

- Added parseTwilioError() with clear messages and hints for common Twilio codes.

- API er

2. Debug Logging

File: src/r

- Logs on send-otp: request context and failures (route, phone, user-agent, error details).

3. OTP Abuse Protection

Files: src

- Middleware on POST /api/auth/send-otp - runs before Twilio is called.

- Same

Per phone: 3 / 24h - Stop same number spam
Per phone cooldown: 90 sec - Stop rapid resends
Per IP: 8 / hour - Stop scripts from one IP
Distinct phones per IP: 5 / hour - Stop SMS pumping pattern
Global daily cap: 100 / day - Financial fuse (max SMS/day)
IP auto-block: 24 hours - Block abusive IPs after flood

4. Region Rules

Files: src

- US (+1): all numbers allowed (with rate limits above).

- Pakist

- +923467893622

- +9231

Environment Variables (Set on Server)

OTP_PROTI

Important: If server .env has OTP_ALLOWED_PREFIXES=+1,+92, remove +92 or Pakistan whitelist won't work.

Twilio Console Actions (Manual, No Code)

- Disabl

Files Touched

src/utils/s

src/modules/auth/service.js: Twilio error throwing, lookup auth errors
src/utils/apiError.js: twilio field in error responses
src/modules/auth/controller.js: send-otp debug logs
src/utils/otpProtection.js: Rate limits, region rules, PK whitelist
src/middlewares/otpSendGuard.js: Middleware wrapper
src/modules/auth/routes.js: otpSendGuard on send-otp
src/config/env.js: OTP protection config

Log Messages to Watch

otp.prote

otp.protection.region_blocked -> Blocked country/number
otp.protection.blocked -> Rate limit hit
otp.protection.ip_blocked -> IP auto-blocked
otp.protection.global_daily_cap_reached -> Daily SMS cap hit
auth.send-otp.failure -> send-otp failed

How Protection Layers Work

```
Request
```

Max theoretical OTP spend = OTP_GLOBAL_DAILY_MAX x cost per SMS
(e.g. 100 x ~$0.05 = ~$5/day)